

APEX SENTINEL ARCHITECTURE SPECIFICATION

Enterprise Next-Generation Autonomous Threat Defense, Prevention & SOAR Platform

1. Executive Summary & System Overview

Apex Sentinel is a distributed, high-throughput Intrusion Detection & Prevention System (IDS/IPS) and Security Orchestration, Automation, and Response (SOAR) architecture. It is engineered for zero-day exploit interception, real-time mathematical anomaly detection, hardware/eBPF kernel discard enforcement, and sub-second adversary containment (Mean-Time-To-Contain: MTTC < 0.4s).

The architecture unifies signature-based deep packet inspection (Suricata 7), asynchronous stream buffering (Apache Kafka), vectorized log transport (Timber Vector), an unsupervised mathematical AI engine (Shannon entropy, byte variance, trigram modeling), and multi-channel reactive presentation (Next.js 14 & WebSocket bus).

2. Enterprise Technology Stack

Layer / Tier	Technology	Version	Role in Architecture
Presentation Layer	Next.js App Router (Standalone)	14.2.5	Production SPA/SSR dashboard with WCAG AAA contrast, reactive charts, and tactical radar.
Component UI Engine	React 18 & Recharts	18.2.0	Declarative state, Threat Posture Gauges, MITRE matrix heatmaps, live telemetry hooks.
Backend Core API	FastAPI / Uvicorn ASGI	0.111.0	High-throughput async REST API, WebSocket broadcast, and security middleware engine.
Data Serialization	Pydantic v2	2.7.0	Strict runtime input validation, type coercion, and JSON schema guarantees.
Relational Database	PostgreSQL	16.2	ACID storage for alerts, incidents, rules, users, audit logs, blocked IPs, and threat intel.
Streaming Buffer	Apache Kafka (KRaft)	3.8.1	Distributed partitioned event stream decoupling high-volume edge probes from analytics.
Cache & Pub/Sub	Redis In-Memory Bus	7.2 Alpine	Sub-millisecond multi-channel alert distribution, rate limiting, and session tracking.
DPI Network Sensor	Suricata (AF_PACKET)	7.0.6	Multi-threaded deep packet inspection engine monitoring raw host and bridge interfaces.
Log Aggregation	Timber Vector	0.38.0	Ultra-lightweight Rust pipeline ingesting Suricata EVE JSON events into Kafka topics.
Log Analytics	OpenSearch	2.17.1	Distributed document indexing for historical forensic search and security event traces.
Observability	Prometheus & Grafana	v2.51 / 10.4	Time-series metric scraping, latency monitoring, and infrastructure telemetry.
Orchestration	Docker & Compose	v2.x	Isolated multi-container bridge networking with health check automations.

3. End-to-End Request & Ingress Flows

Flow 1: Live Wire Ingress to Autonomous Severing (Suricata → Prevention)

- Adversary Transmits Exploit:** An incoming raw packet (e.g. Log4Shell `{jndi:...}` or Spring4Shell RCE) reaches the monitored interface.
- Suricata Packet Inspection:** Promiscuous AF_PACKET engine detects signature violation (SID 1000005) and emits an EVE JSON record to `/var/log/suricata/eve.json`.
- Vector Streamer:** Vector tails EVE JSON, transforms headers into standard format, and writes asynchronously to Kafka topic `ids.alerts`.
- Detection Engine Consumer:** Multi-threaded Python consumer pulls batch, normalizes fields, and sends HTTP POST to `/api/alerts`.
- Mathematical AI Evaluation:** FastAPI passes telemetry to `ai_engine.py`. The engine computes Shannon entropy, byte variance, delimiter density, and nesting score to output an Anomaly Score (0.98).
- Autonomous IPS Sever:** Because Severity is CRITICAL and Risk Score is ≥ 80 , the engine synchronously inserts the attacker IP into `blocked_ips`, marks the alert as `AUTO_BLOCKED`, creates a `CONTAINED` incident, and issues an eBPF drop order.
- WebSocket Broadcast:** Redis publishes event across channel `ids.alerts`. WebSocket pushes JSON frame to the browser in under 0.4 seconds.

Flow 2: Web & API Gateway Request Security Middleware

Every HTTP request hitting the FastAPI backend passes through `IPSGatewayMiddleware` before reaching any controller:

- Step 1: IP Quarantine Check:** Compares source IP against `blocked_ips`. If quarantined, immediately aborts with HTTP 403 Forbidden.
- Step 2: Deep Exploit Regex Scan:** Evaluates URI path, query parameters, headers, and body for SQLi, XSS, Path Traversal (`../etc/passwd`), and Log4j tokens.
- Step 3: Sliding-Window Rate Limiter:** Enforces max 300 requests/minute per IP to defeat automated DDoS and credential stuffing bursts.
- Step 4: OAuth2 JWT Authentication & RBAC:** Verifies bearer token signature and validates role access (ADMIN, ANALYST, or VIEWER).

Flow 3: Threat Intelligence & Reputation Verification Workflow

When an analyst or automated probe queries an indicator (IP, Domain, or Hash) via `POST /api/threat-intel/lookup`, the backend runs a parameterized search across the indexed `threat_intel` database containing 127 verified IOCs. If a match is found, it returns verified confidence (88%–100%), classification (e.g. `MALICIOUS: COBALT_STRIKE_C2`), and attribution source (CISA, AbuseIPDB, ThreatConnect). If clean, it returns a 10% benign noise floor.

4. Mathematical AI / ML Anomaly Detection Engine

Apex Sentinel avoids fragile keyword-only matching by deploying an unsupervised statistical ML engine (`ai_engine.py`) that vectorizes payloads in under 0.35 milliseconds per packet across 7 mathematical dimensions:

Feature	Mathematical Definition	Security Anomaly Indication
Shannon Entropy	$H(X) = -\sum(p_i * \log_2(p_i))$	High entropy (>5.5) reveals packed shellcode, encrypted C2 beacons, or obfuscation.
Byte Variance	$Var(B) = (1/N) * \sum((b_i - \mu)^2)$	Abnormal dispersion of ASCII byte distributions in network streams.
Non-Printable Ratio	$Count(b < 32 \text{ or } b > 126) / Total_Bytes$	Detects raw binary execution payloads transmitted over text protocols (HTTP/DNS).
Delimiter Density	$Count(' " ; < > -- \$ \{ \}) / Total_Chars$	High density indicates SQL injection, command chaining, or template exploitation.

Nesting Depth Score	Max open bracket/brace depth	Identifies nested exploit expressions such as <code>\$(jndi:ldap://\${...})</code> or nested subqueries.
Trigram Rarity	Divergence from baseline n-gram corpus	Unusual character sequences indicative of randomized exploit payloads or DGA domains.
Packet Velocity	$\text{delta}(\text{Packet_Count}) / \text{delta}(\text{Time})$	Monitors sudden volumetric bursts indicative of DDoS or brute force bursts.

Sigmoid Anomaly Mapping Formula:

$\text{Anomaly_Score} = 1.0 / (1.0 + \exp(-1.3 * (\text{Composite_Distance} - 1.6)))$

Confidence Calculation Formula:

$\text{Confidence_Pct} = \min(99, \text{int}(\max(75, \text{Anomaly_Score} * 95 + 4)))$

5. Backend Performance & Engine Optimizations

- **Sub-Second MTTC (< 0.4s):** Critical threats trigger synchronized IP insertion into `blocked_ips`, eBPF drop rules, and WebSocket broadcast in milliseconds.
- **B-Tree & GIN Indexing:** PostgreSQL indices (`idx_alerts_timestamp`, `idx_alerts_severity`, `idx_intel_value`) ensure millisecond queries across 100,000+ records.
- **Decoupled Kafka Buffering:** High-speed edge packet spikes are absorbed by Kafka's 3-partition cluster, eliminating HTTP request dropouts during DDoS attacks.
- **Multi-Channel Redis Pub/Sub:** WebSockets consume from dedicated Redis channels, maintaining ultra-low CPU utilization without database polling loops.

6. Security, Compliance & Role-Based Access Control (RBAC)

- **ADMIN:** Full read/write authority across alerts, incidents, detection rules, SOAR playbooks, and user credentials.
- **ANALYST:** Deep Packet Inspection (DPI) access, PCAP viewer, incident lifecycle management (cannot delete users or core settings).
- **VIEWER:** Read-only access to overview charts, network topology, and metrics (state changes return HTTP 403 Forbidden).
- **Immutable Audit Logging:** Every administrative and security action is written to `audit_logs` with actor email, timestamp, IP, and cryptographic before/after JSON diffs.